Universidad Mariano Gálvez de Guatemala

Lic. Raúl Bonilla

Microeconomía

Ing. Sistemas de la Información y Ciencias de la Computación Sábados, "A"



0900-24-4296 Pavel Alexander Palma Carrillo 100%

0900-24-98 Josseline Paola Lool Turcios 100%

0900-25-15929 Daniela Grajeda 100%

0900-25-30457 Edgar Alejandro Velásquez Velásquez 100%

0900 21 15956 Miriam Rosalva Pivaral Marroquín 100%

0900-18-5283 Margia Saraí García Morales 100%

Proyecto Final, SecureInfo

17/10/2026

I. Tabla de Contenido

I. Tabla de Contenido 2
II. Introducción 10
III. Problemática 12
IV. Alcance del proyecto 12
V. Objetivos 14
5.1 Objetivo General 14
5.2 Objetivos Específicos 14
VI. Justificación 15
6.1 Importancia y Necesidad 15
6.2 Impacto Económico 15
6.3 Impacto Social y Beneficios 15
VII. Estudio De Mercado 16
7.1 Introducción al mercado 16
7.2 Análisis de la demanda 16
7.2.1 Qué se demanda, exactamente 16
7.2.2 Segmentos de demanda 17
7.2.3 Elasticidad y disposición a pagar 17
7.3 Análisis de la competencia 18
7.3.1 Ventaja del paquete 19
7.3.2 Estructura del mercado 20
7.3.3 Conclusión del estudio de mercado 20
VIII. Planificación 22

8.1 Cronograma 22

8.1.1 Reloj del servicio (un cliente) 22

8.1.2 Presupuesto 23

8.1.3 Costo de un paquete (cuatro semanas) 23

8.1.4 Resultado económico por paquete 25

8.1.5 Recursos 26

8.1.6 Riesgos 27

8.1.7 Base legal de la investigación 29

8.1.8 Referencias de política y de contexto, no de ley 30

IX. La Empresa 32

9.1 Origen 32

9.2 Nombre 32

9.3 Ubicación 32

9.4 Jerarquía 33

9.5 Organigrama 33

9.6 Departamentos 34

9.6.1 Área de Consultoría y Diagnóstico 34

9.6.2 Área de Políticas y Documentación 34

9.6.3 Área de Capacitación 34

9.6.4 Área Administrativa y Comunicación 34

9.7 Comunicación 35

9.8 Cultura Empresarial 36

9.9 Misión y Visión 36

9.9.1 Misión 36
9.9.2 Visión 36
9.10 Tecnología 36
9.11 Procedimientos y Políticas 37
9.12 Número de Empleados 38
9.13 Horarios 38
9.14 Metas 39
9.14.1 Corto plazo 39
9.14.2 Mediano plazo 39
9.14.3 Largo plazo 40
9.15 Principios 40
X. Ingeniería del Proyecto 42
XI. Proceso de Producción 43
XII. Flujograma Del Proyecto 46
XIII. TECNOLOGÌA DEL PROYECTO 47
13.1 Identificación de las necesidades tecnológicas 47
13.2 Selección y adquisición de herramientas 48
13.3 Organización de los recursos tecnológicos 48
13.4 Uso de la tecnología para la comunicación 48
13.5 Uso de inteligencia artificial 49
13.6 Optimización del trabajo en equipo 49
13.7 Protección y respaldo de la información 50
13.8 Evaluación y mejora continua 51

XIV. Manual de Marca 52
14.1 ¿Cómo nació SecureInfo? 52
14.2 Logotipo 52
14.3 Espacio de Seguridad 53
14.4 Tamaño Mínimo 54
14.5 Paleta de Colores 54
14.6 Tipografía 55
14.7 ¿Quiénes Somos? 55
XV. Caso de Implementación de Servicio 56
15.1 Entidad Solicitante 56
15.1.1 Descripción Institucional. 56
15.1.2 Antecedentes y Situación Actual 56
XVI. Índice 58
XVII. Implementación de Políticas de Seguridad de la Información 62
17.1 Reunión inicial 62
17.2 Cronograma 62
17.3 Presupuesto de Servicios de Consultoría Informática 64
17.4 Notas del presupuesto: 65
XVIII. Aprobación de Presupuesto 65
XIX. Documento de Aprobación de Presupuesto 66
XX. Revisión de Equipos y Registro de incidentes 67
20.1 Uso de Dispositivos USB Personales. 67
20.2 Contraseñas Débiles y Compartidas. 68

20.3 Reenvío de Información Sensible a Correos Externos. 68
20.4 Falta de respaldos actualizados. 68
20.5 Registro de incidentes. 69
20.6 Conclusión del diagnóstico. 69
XXI. Entrevistas al Personal 69
21.1 Hallazgos Principales 69
21.1.1 Uso de Dispositivos Externos 70
21.1.2 Contraseñas y Acceso 70
21.1.3 Manejo de Correo Electrónico 70
21.1.4 Respaldos y Pérdida de información 71
21.1.5 Percepción general del personal 71
21.1.6 Conclusión de las entrevistas 71
XXII. Identificación de Debilidades 71
XXIII. Políticas de Seguridad de la Información 73
23.1 Política 001 73
23.1.1 Nombre de la política 73
23.1.2 Objetivo 74
23.1.3 Alcance 74
23.1.4 Encargado de la política 74
23.1.5 Fecha de vigencia y revisión 74
23.1.6 Lineamientos principales 74
23.2 Política 002 75
23.2.1 Nombre de la política 75

23.2.2 Objetivo 75
23.2.3 Alcance 75
23.2.4 Encargado de la política 75
23.2.5 Fecha de vigencia y revisión 75
23.2.6 Lineamientos principales 75
23.3 Política 003 76
23.3.1 Nombre de la política 76
23.3.2 Objetivo 76
23.3.3 Alcance 76
23.3.4 Encargado de la política 76
23.3.5 Fecha de vigencia y revisión 77
23.3.6 Lineamientos principales 77
23.4 Política 004 77
23.4.1 Nombre de la política 77
23.4.2 Objetivo 77
23.4.3 Alcance 78
23.4.4 Encargado de la política 78
23.4.5 Fecha de vigencia y revisión 78
23.4.6 Lineamientos principales 78
23.5 Política 005 79
23.5.1 Nombre de la política 79
23.5.2 Objetivo 79
23.5.3 Alcance 79

23.5.4 Encargado de la política 79
23.5.5 Fecha de vigencia y revisión 79
23.5.6 Lineamientos principales 79
XXIV. Manual de Políticas de Seguridad de la Información 80
XXV. Capacitación al Personal 81
25.1 Objetivo de la Capacitación. 81
25.2 Agenda desarrollada. 82
25.3. 82
25.4 Materiales Entregados. 82
25.5 Resultados de la capacitación. 83
25.6 Conclusión de la capacitación. 83
XXVI. Monitoreo de Cumplimiento 84
26.1 Período 84
26.2 Responsables 84
26.3 Objetivo 84
26.4 Metodología. 84
26.5 Hallazgos principales. 85
26.6 Resultados del Monitoreo. 86
26.7 Conclusión del Monitoreo 87
XXVII. Reporte de Incidentes 87
27.1 Incidentes Previos a la Consultoría Informática 87
27.2 Incidentes Detectados Durante el Monitoreo. 89
27.3 Comparativa Antes y Después de la Consultoría Informática 90

27.4 Conclusiones del Reporte 91
27.4.1 Antes de la Consultoría Informática 91
27.4.2 Después de la Consultoría Informática 91
27.4.3 Recomendación 91
XXVIII. Encuesta de Satisfacción al Personal 91
28.1 Preguntas y resultados 92
28.2 Resumen general de la encuesta 95
28.3 Comentarios abiertos destacados 95
XXIX. Conclusión de la encuesta 96
XXX. Recomendaciones 96
30.1 Mantener las auditorías periódicas. 96
30.2 Repetir la capacitación anualmente. 96
30.3 Actualizar las políticas según la evolución tecnológica. 97
30.4 Implementar autenticación de dos factores (2FA) 97
30.5 Fomentar una cultura de seguridad 97
30.6 Lecciones Aprendidas del Caso Práctico 97
XXXI. Conclusión 99

II. Introducción

En la actualidad, el uso de la tecnología y la transformación digital han generado nuevas oportunidades para el desarrollo de las empresas e instituciones; sin embargo, también han incrementado la necesidad de proteger la información que se maneja diariamente. Las organizaciones utilizan computadoras, correos electrónicos, dispositivos de almacenamiento y plataformas digitales para realizar sus actividades, pero no todas cuentan con políticas, procedimientos y controles adecuados que permitan prevenir riesgos relacionados con la pérdida, divulgación o uso inadecuado de la información.

Ante esta necesidad surge SECUREINFO, una propuesta empresarial enfocada en brindar servicios de seguridad de la información, dirigidos principalmente a las micro, pequeñas y medianas empresas, así como a instituciones y entidades públicas de Guatemala. Su propósito es ayudar a las organizaciones a identificar riesgos, establecer políticas internas, elaborar manuales y procedimientos y capacitar a sus colaboradores para promover una cultura de prevención, responsabilidad y protección de la información.

El presente proyecto desarrolla aspectos administrativos, organizacionales, tecnológicos y económicos necesarios para comprender el funcionamiento de la empresa y la viabilidad de su propuesta de servicios. Asimismo, aborda elementos relacionados con el estudio de mercado, la identificación de clientes potenciales, la oferta y la demanda, los recursos necesarios para la prestación de los servicios y los costos asociados con las operaciones. Estos aspectos permiten analizar la oportunidad de ofrecer soluciones accesibles y adaptadas a las necesidades de organizaciones que no cuentan con un departamento especializado en seguridad de la información.

De igual manera, se destaca la importancia de utilizar eficientemente los recursos humanos, tecnológicos y financieros, así como de incorporar herramientas digitales e inteligencia artificial como apoyo para optimizar los procesos, mejorar la comunicación y fortalecer el trabajo en equipo, siempre bajo criterios de confidencialidad y uso responsable de la información.

el proyecto SECUREINFO busca demostrar que la seguridad de la información representa una necesidad importante para las organizaciones y al mismo tiempo, una oportunidad de emprendimiento. Mediante una estructura organizacional flexible, servicios especializados y una estrategia orientada a las necesidades del mercado guatemalteco, la empresa pretende contribuir a la prevención de riesgos, al uso responsable de la tecnología y al fortalecimiento de la confianza en el manejo de la información.

III. Problemática

Las organizaciones públicas y privadas gestionan volúmenes críticos de información sensible (expedientes, datos personales, registros financieros y operativos) sin contar con un marco normativo interno adecuado. Actualmente, la falta de regulaciones sobre el uso de dispositivos, la ausencia de controles de acceso y la escasa cultura de prevención frente a amenazas cibernéticas (malware, phishing, exfiltración de datos) exponen a las entidades a:

- Pérdida o fuga de información sensible.
- Sanciones legales y multas regulatorias.
- Daño severo a la reputación institucional.
- Costos imprevistos por remediación de incidentes.
- La necesidad nace de transformar esta vulnerabilidad operativa en un entorno seguro y normado mediante una solución integral de costo accesible.

IV. Alcance del proyecto

El proyecto comprende el diagnóstico, diseño, documentación y capacitación inicial en materia de seguridad de la información para la entidad cliente.

Incluye:

- Diagnóstico de riesgos: Evaluación cualitativa de vulnerabilidades operativas (uso de USB, gestión de contraseñas, accesos).

- Diseño de políticas: Elaboración de 5 políticas operativas clave (Dispositivos externos, contraseñas, Control de acceso, Respaldos y Navegación segura).

- Manual de Políticas de Seguridad: Entregable documental con políticas, procedimientos y asignación de roles.

- Taller de Capacitación: Sesión virtual de 2 horas orientada al personal general.

- Plan de Implementación y Monitoreo: Cronograma de adopción y métricas de cumplimiento.

Fuera del alcance (Exclusiones):

- Adquisición o instalación de software/hardware de seguridad (antivirus, firewalls, etc.).

- Configuración técnica de servidores o redes.

- Auditorías técnicas posteriores o pruebas de penetración (*pentesting*).

V. Objetivos

5.1 Objetivo General

Fortalecer la gestión y protección de la información sensible en las organizaciones mediante la implementación de un marco normativo interno, la entrega de documentación formal y la capacitación del personal en un periodo estimado de 4 semanas.

5.2 Objetivos Específicos

- Identificar el 100% de las vulnerabilidades operativas prioritarias en el uso diario de la información durante la fase de diagnóstico.
- Redactar e integrar 5 políticas clave de seguridad alineadas a las necesidades operativas de la entidad.
- Capacitar al personal clave mediante un taller práctico de para alcanzar al menos un 80% de comprensión sobre los nuevos protocolos.
- Entregar el Manual de Políticas y el Plan de Monitoreo como guía formal de cumplimiento continuo.

VI. Justificación

6.1 Importancia y Necesidad

La seguridad de la información ha dejado de ser un asunto puramente técnico para convertirse en un pilar de gobernanza organizativa. La mayoría de las brechas de seguridad ocurren por errores humanos o falta de políticas básicas. Este proyecto aporta la estructura normativa que la entidad necesita para operar con control y orden.

6.2 Impacto Económico

Por una inversión única la entidad mitiga riesgos cuyo costo financiero (remediación, pérdida de clientes, paros operacionales o multas) supera sustancialmente el valor de la consultoría.

6.3 Impacto Social y Beneficios

- Protección ciudadana/usuario: Garantiza la confidencialidad de los datos personales manejados por la institución.
- Confianza institucional: Refuerza la credibilidad pública y comercial de la entidad frente a terceros.
- Cultura preventiva: Transforma la conducta de los colaboradores, promoviendo el uso responsable de los recursos tecnológicos.

VII. Estudio De Mercado

7.1 Introducción al mercado

En microeconomía, un mercado existe cuando hay un bien o servicio que alguien está dispuesto a comprar y alguien dispuesto a vender, a un precio que ambos aceptan. El servicio que propone este proyecto no es un software ni un firewall: es un paquete de consultoría que traduce un problema cotidiano —el mal manejo de información sensible— en reglas claras, un manual y un taller. Ese producto se vende en un mercado imperfecto, con información incompleta y con una brecha enorme entre lo que las entidades necesitan y lo que hoy pueden pagar.

Guatemala está digitalizándose más rápido de lo que está protegiendo esa digitalización. La factura electrónica ya es obligatoria para el contribuyente formal, las municipalidades y ministerios cargan expedientes en sistemas, y las MIPYMES atienden clientes por WhatsApp, correo y nube. Al mismo tiempo, el país sigue sin una ley de ciberseguridad aprobada y las instituciones públicas fueron blanco de una ola de incidentes en 2026. Ese desajuste entre uso de datos y capacidad de protegerlos es, en términos simples, la demanda no satisfecha de este proyecto.

7.2 Análisis de la demanda

7.2.1 Qué se demanda, exactamente

La demanda no es “ciberseguridad” en abstracto. Lo que el cliente potencial pide —aunque a veces no sepa nombrarlo— es un conjunto de reglas aplicables: quién puede conectar un USB, cada cuánto se cambia una contraseña, quién entra a un expediente, dónde se guarda el respaldo y qué se puede abrir en el navegador. En lenguaje microeconómico, el bien es un servicio profesional

de baja intensidad tecnológica y alta intensidad normativa. El comprador no está comprando código; está comprando reducción de riesgo, orden interno y un documento que puede mostrar a una auditoría, a un jefe o a un concejo municipal.

7.2.2 Segmentos de demanda

Guatemala tiene 340 municipios. Eso no significa 340 clientes inmediatos, pero sí un piso institucional enorme: cada municipalidad es sujeto obligado de la Ley de Acceso a la Información Pública (Decreto 57-2008) y maneja datos de vecinos. En el sector privado, las MIPYMES concentran la casi totalidad del tejido empresarial. Estimaciones recientes del Ministerio de Economía y del Registro Mercantil siguen mostrando que micro, pequeñas y medianas empresas superan el 95 % del parque formal. Ese volumen importa menos como “millón de clientes” y más como señal de que el mercado no está saturado: la mayoría de esas unidades no tiene un oficial de seguridad ni un manual interno.

7.2.3 Elasticidad y disposición a pagar

A Q15,000 el paquete es un bien de demanda relativamente elástica en las MIPYMES y menos elástica en una municipalidad mediana o un ministerio que acaba de vivir un incidente. Dicho en limpio: si el precio sube a Q25,000 o Q40,000, la pequeña empresa se sale del mercado y se queda en la inacción. Si baja a Q8,000, entra más volumen, pero se pierde margen y se satura al equipo. Q15,000 está pensado como precio de penetración: cabe en una cotización corta, cubre diagnóstico, cinco a siete políticas, manual y taller de dos horas, y se compara favorablemente con una asesoría legal o una implementación ISO 27001, que suelen cotizarse por decenas de miles de quetzales y varios meses.

El beneficio social —proteger datos de ciudadanos, evitar multas y sostener confianza— no es un adorno. En microeconomía es una externalidad positiva: el cliente paga por su propia protección, pero el vecino, el contribuyente y el paciente también ganan porque sus datos dejan de circular en un USB sin control. Esa externalidad justifica, más adelante, alianzas con municipalidades o cámaras, no un precio de caridad.

7.3 Análisis de la competencia

El mercado guatemalteco de ciberseguridad no está vacío. Lo que está incompleto es el peldaño de abajo: políticas simples, escritas en español claro, con un taller de dos horas y un precio que una municipalidad o una empresa de 25 personas puede firmar sin comité de compras internacional.

Tabla 1

análisis de la competencia

Big Four y firmas grandes (Deloitte, PwC, KPMG, EY)	Auditoría, ISO 27001, gobierno de TI, pentesting para banca y corporativos.	Precio y alcance de gran empresa. Una MIPYME o una comuna pequeña no entra a esa conversación.
Consultoras locales especializadas (p. ej. Scube y similares)	Pentesting, respuesta a incidentes, arquitecturas, PCI DSS, ISO.	Muy competentes en lo técnico. El producto es otro: no un manual de 5 políticas + taller corto a precio cerrado.

Bufetes y asesoría legal	Dictámenes, contratos, cumplimiento del 57-2008.	Resuelven el papel jurídico, no el hábito del empleado ni el USB en la oficina.
Vendedores de antivirus, firewall y nube	Licencias y hardware.	Venden la herramienta. Sin política, la herramienta se instala y se ignora.
Inacción (competidor silencioso)	No gastar. Esperar a que "no pase nada".	Es el rival más fuerte. Compite con precio cero hoy y un costo esperado alto mañana (fuga, ransom, reputación).

Nota: análisis realizado bajo las diferentes competencias que se manejan en Guatemala

7.3.1 Ventaja del paquete

La ventaja no es "somos más baratos que Deloitte". Esa comparación es tramposa y se nota. La ventaja es otra:

- Integralidad acotada: diagnóstico + políticas + manual + taller + plan de monitoreo. El cliente no arma el rompecabezas con tres proveedores.
- Precio cerrado y plazo corto: Q15,000 cierra un alcance de cuatro semanas. Eso baja el costo de transacción: no hay RFP de 40 páginas.

- Lenguaje operativo, no de auditoría: las políticas están pensadas para USB, contraseñas, correo, respaldo y acceso. No prometen ISO ni SOC 24/7.

- Entregable visible: el producto tangible (manual, informe de diagnóstico, lista de asistencia del taller) se puede mostrar. En un mercado con información asimétrica, lo tangible reduce la desconfianza.

7.3.2 Estructura del mercado

En el segmento alto (bancos, telecom, grandes ministerios) el mercado se parece a un oligopolio de firmas especializadas. En el segmento al que apunta este proyecto —municipio mediano y MIPYME formal— el mercado se parece más a competencia monopolística: muchos oferentes posibles, productos parecidos pero diferenciados por precio, tono y alcance, y barreras de entrada bajas. Un equipo pequeño puede entrar si demuestra método. También puede salir si no cierra el primer piloto. Esa facilidad de entrada es, a la vez, oportunidad y riesgo: mañana puede aparecer otro paquete similar en una cámara empresarial.

7.3.3 Conclusión del estudio de mercado

Hay demanda real, no inventada para la rúbrica. Se sostiene en tres hechos que se pueden citar: un tejido empresarial y municipal que ya maneja datos sensibles; un vacío legal que obliga a cada entidad a escribir sus propias reglas; y una secuencia de incidentes públicos en 2025-2026 que sacó el tema de los pasillos de TI y lo puso en la primera plana. La competencia fuerte está arriba (firmas técnicas y legales caras) o abajo (no hacer nada). El hueco del medio —política escrita, taller breve, precio cerrado— está poco ocupado. Ese es el espacio de este paquete.

La recomendación es vender un entregable de cuatro semanas a municipalidades intermedias y MIPYMES formales del área metropolitana, documentar el primer caso y, con esa evidencia, abrir la segunda ronda. El mercado existe. Lo que no existe todavía es la costumbre de pagar por prevenir. El piloto tiene que crear esa costumbre, un cliente a la vez.

VIII. Planificación

Planificar, en este proyecto, no es llenar un cronograma para la rúbrica. Es decidir en qué orden se gasta el tiempo, cuánto cuesta entregar un paquete a Q15,000 y qué puede torcer el plan. El alcance ya quedó cerrado en la iniciación: diagnóstico de riesgos, diseño de cinco a siete políticas, manual, taller piloto de dos horas y un plan corto de monitoreo. No entra software, no entra auditoría forense y no entra implementación técnica de firewalls.

8.1 Cronograma

8.1.1 Reloj del servicio (un cliente)

Cada contrato se ejecuta en 20 días hábiles. Si el encargado de TI no aparece o el concejo municipal pide una semana extra, el colchón está en la semana 4, no al inicio.

Tabla 2

Cronograma de Servicios

Semana	Fase	Actividades	Entregable
1	Diagnóstico	Reunión de arranque, entrevista a TI, recorrido de equipos, encuesta corta a 8-12 empleados, inventario de incidentes.	Informe de hallazgos (5-8 páginas) y mapa de riesgos.
2	Diseño de políticas	Redacción de 5 a 7 políticas, validación legal mínima con el 57-2008, revisión con el cliente.	Borrador de políticas comentado por el cliente.

3	Manual y taller	Diagramación del manual, ensayo del taller, impartición de 2 horas, lista de asistencia, casos prácticos.	Manual impreso/PDF y acta del taller.
4	Monitoreo y cierre	Lista de chequeo de cumplimiento, encuesta de satisfacción, informe final, transferencia de archivos.	Informe de cierre y cronograma de seguimiento a 30 días.

Nota: Plan de Cronograma que se emplea para los servicios que se ofrecen

8.1.2 Presupuesto

Lógica del gasto: El precio de venta del paquete es Q15,000. El presupuesto que sigue estima el costo de producir un paquete en el Área Metropolitana (Guatemala), con un equipo estudiantil que valora sus horas a una tarifa de consultoría junior —no a salario mínimo, porque el producto no es mano de obra no calificada, pero tampoco a tarifa de firma internacional—. El salario mínimo no agrícola CE1 2026 es Q4,002.28 mensuales más Q250 de bonificación incentivo (Acuerdo Gubernativo 256-2025). Eso sirve de piso, no de cotización. Una hora de consultoría junior en este proyecto se valora en Q75.

8.1.3 Costo de un paquete (cuatro semanas)

Tabla 3

Costos de paquete que se ofrecen

Rubro	Cantidad	Costo unitario	Total, Q	Método

Honorarios — diagnóstico e entrevistas (Sem. 1)	24 h	Q75	1,800	2 personas × 12 h
Honorarios — redacción de políticas (Sem. 2)	20 h	Q75	1,500	Redacción + revisión
Honorarios — manual y taller (Sem. 3)	18 h	Q75	1,350	Diseño + 2 h de taller + ensayo
Honorarios — monitoreo y cierre (Sem. 4)	10 h	Q75	750	Informe y encuesta
Transporte urbano (reuniones y taller)	8 viajes	Q40	320	Bus/Uber corto AM
Impresión del manual (20-25 ejemplares B/N + portada)	25 und.	Q18	450	Copistería local
Material del taller (lista, credenciales, agua)	1 lote	Q200	200	Gasto directo
Herramientas digitales (prorrateo mensual Workspace/Meet)	1 mes	Q150	150	Cuenta educativa / plan básico

Comunicación (datos móviles / llamadas)	1 mes	Q100	100	Prepago
Imprevistos (10 % sobre costos directos)	—	—	662	Reserva
Costo Total De Producción			7,282	

Nota: Plan de presupuesto basado en los gastos administrativos de la empresa

8.1.4 Resultado económico por paquete

Tabla 4

Resultados económicos de paquetes

Concepto	Quetzales
Precio de venta	Q15,000
Costo de producción (incluye reserva)	Q7,282
Margen bruto	Q7,718
Margen sobre ventas	51.5 %

Nota: Márgenes de venta sobre las ganancias por proyecto

Ese margen no es “ganancia de dueños”. Cubre horas no cobradas de coordinación, el riesgo de que un cliente cancele a media semana y, si el piloto escala, un fondo para imprimir más manuales. Si el grupo entrega 8 paquetes en un año, el ingreso sería Q120,000 y el costo directo alrededor de Q58,000. Son números de aula, no de sociedad anónima, pero cierran: el precio no está por debajo del costo y no está en la órbita de una ISO 27001.

Si el cliente es una municipalidad, el cobro entra como consultoría o capacitación, no como obra. La Ley de Contrataciones del Estado (Decreto 57-92 y reformas) permite compras de bajo monto por cotización cuando no se cruza el umbral de licitación. El proyecto, a propósito, se quedó en Q15,000 para no pelearse con un proceso de meses.

8.1.5 Recursos

Tabla 5

Recursos utilizados para los clientes

Tipo	Qué se usa	De dónde sale
Humanos	5 integrantes del grupo; roles de diagnóstico, redacción, taller, diseño y coordinación. Un referente de TI del cliente (no se paga, se agenda).	Equipo del curso. No se contrata personal externo en el piloto.
Físicos	2-3 laptops, celular, USB institucional de respaldo, impresora de copistería, salón del cliente para el taller.	Equipo propio + espacio del cliente. No se alquila oficina.

Tecnológicos	Google Workspace o cuenta educativa, Meet, Word/Docs, Drive con carpeta del cliente, formularios para la encuesta.	Licencias gratuitas o de bajo costo. Nada de software de pentesting en el alcance.
Financieros	Caja chica de Q1,000 para transporte e impresión antes del cobro. El resto se cubre con el anticipo o al cierre.	Aporte del grupo o anticipo del 40 % al firmar.
Intangibles	Plantillas de políticas, checklist de diagnóstico, tono del manual, contactos en Mixco / AM.	Se construyen en las semanas 3-6 del cronograma académico.

Nota: Recursos utilizado por la empresa para los clientes.

8.1.6 Riesgos

Riesgo es lo que puede impedir que el paquete se entregue a tiempo, al costo y con la calidad prometida. Se listan los que sí pueden pasar en Guatemala, no un catálogo genérico de PMP.

Tabla 6

Riesgos que aparecen con clientes

Riesgo	Prob. / Impacto	Cómo se nota	Qué se hace
El cliente no da acceso ni entrevistas	Alta / Alto	Semana 1 se va sin hallazgos. El diagnóstico	Carta de compromiso al firmar. Si a día 4 no hay entrevistas, se pausa el reloj o se cancela con cobro mínimo.

		queda en opinión.	
Retraso del taller por feriado, bloqueo o cambio de sala	Media / Medio	La semana 3 se corre a la 4.	Fecha del taller se agenda en el día 1. Plan B: taller por Meet.
Alcance inflado (“ya que están, auditen el servidor”)	Alta / Alto	El equipo trabaja de más y el margen se come.	Anexo de alcance firmado. Lo técnico se deriva; no se improvisa.
Baja asistencia al taller	Media / Medio	El manual existe, pero la conducta no cambia.	Convocatoria del jefe directo. Cupo mínimo de 8 personas o se reprograma.
Fuga o mal uso de datos vistos en el diagnóstico	Baja / Muy alto	El consultor se vuelve el problema que vino a resolver.	Acuerdo de confidencialidad. Datos del cliente no salen del Drive del proyecto. Nada de USB personales —el equipo se aplica su propia política.
El cliente no paga al cierre	Media / Alto	Se gastó transporte e impresión a pérdida.	Anticipo 40 % (Q6,000). Entrega del PDF final contra saldo.

Cambio de autoridades municipales a media ejecución	Media / Alto	El patrocinador se va y el contrato queda en el aire.	El contrato se firma con la institución, no con la persona. Se deja constancia en acta.
Sobrecarga del grupo	Alta / Medio	El cronograma de 12 semanas se aplasta en la 11.	Los dos hitos de control. Si un integrante se cae, el rol tiene suplente escrito.

Nota: Se toman bases de riesgo al realizar los manuales o políticas en poco tiempo

8.1.7 Base legal de la investigación

- Constitución Política de la República. Artículo 31 (acceso a archivos y registros estatales y hábeas data) y artículo 44 (los derechos constitucionales no se agotan en el texto). Cualquier política que diseñemos tiene que respetar intimidad y acceso, no solo “cerrar USB”.

- Decreto 57-2008, Ley de Acceso a la Información Pública. Es la pieza más útil del marco actual. Define datos personales y datos sensibles, obliga a los sujetos —ministerios, municipalidades, autónomas y privados que administran fondos públicos— a resguardar esa información, regula el hábeas data (arts. 30 a 34) y pone límites de confidencialidad y reserva. El manual del proyecto cita esta ley porque es la que un auditor o un vecino sí puede invocar hoy.

- Código Penal, Decreto 17-73. No es una ley de ciberseguridad. Tipifica estafa, revelación de secretos, alteración de registros y delitos contra el patrimonio que se pueden cometer con un computador. Sirve como red mínima, no como catálogo de ciberdelitos al estilo del Convenio de Budapest.

- Ley de Contrataciones del Estado, Decreto 57-92 y reformas. Importa si el cliente es público: el paquete se cotiza como servicio de consultoría/capacitación de bajo monto, no como desarrollo de software ni como obra.

- Acuerdo Gubernativo 211-2015 y Acuerdo Gubernativo 256-2025. El primero clasifica MIPYMES; el segundo fijo el salario mínimo 2026. Ambos anclan cifras del estudio de mercado y del presupuesto, no la seguridad informática en sí.

8.1.8 Referencias de política y de contexto, no de ley

- Política de Gobierno 2024-2028 y el Comité Nacional de Ciberseguridad (CONCIBER). Muestran intención de Estado, no obligación exigible a una municipalidad de Mixco.

- Global Cybersecurity Index de la UIT (2024). Guatemala aparece en un nivel bajo de madurez. Se usa como diagnóstico de país, no como norma.

- ISO/IEC 27001 e ISO/IEC 27002. Son el lenguaje en el que están escritas las cinco a siete políticas (control de accesos, soportes extraíbles, copias de seguridad, uso aceptable). No se certifica al cliente. Se traduce el estándar a una página que un empleado puede leer.

- La investigación es legal porque no inventa una autoridad que no existe y no vende un sello que el país no emite. Se sostiene en el 57-2008, en la Constitución y en el sentido común

de no esperar a que el Congreso termine la 6347 para poner orden en una oficina. El vacío legislativo no es un problema de la tesis; es parte de la demanda.

- El plan cabe en una frase: cuatro semanas por cliente, doce semanas de curso, Q7,282 de costo contra Q15,000 de precio, recursos de aula más la agenda del cliente, y un marco legal que hoy es incompleto a propósito. Si el grupo respeta el alcance —políticas, manual y taller, no software— el cronograma aguanta. Si alguien promete pentesting para quedar bien en una reunión, el presupuesto y el riesgo se rompen el mismo día.

IX. La Empresa

9.1 Origen

SecureInfo Consultores nace como una iniciativa enfocada en ayudar a pequeñas y medianas empresas, instituciones y entidades públicas a mejorar la forma en que protegen y administran su información.

La idea surge al identificar que muchas organizaciones utilizan computadoras, correos electrónicos, dispositivos USB y servicios digitales diariamente, pero no siempre cuentan con políticas claras que indiquen cómo utilizar estos recursos de manera segura. Por esta razón, la empresa busca brindar una solución accesible mediante servicios de diagnóstico, elaboración de políticas, capacitación y orientación en seguridad de la información.

9.2 Nombre

Nombre comercial: SecureInfo Consultores

El nombre combina los conceptos de seguridad e información, que representan las principales áreas en las que se enfoca la empresa. La palabra “Consultores” identifica que la actividad principal consiste en brindar asesoría y acompañamiento a otras organizaciones.

9.3 Ubicación

La empresa estará ubicada en el Área Metropolitana de Guatemala. Durante su etapa inicial funcionará principalmente bajo una modalidad híbrida, combinando trabajo remoto con visitas a las instalaciones de los clientes.

Esto permite reducir gastos relacionados con el alquiler de una oficina y facilita atender a diferentes organizaciones según sus necesidades.

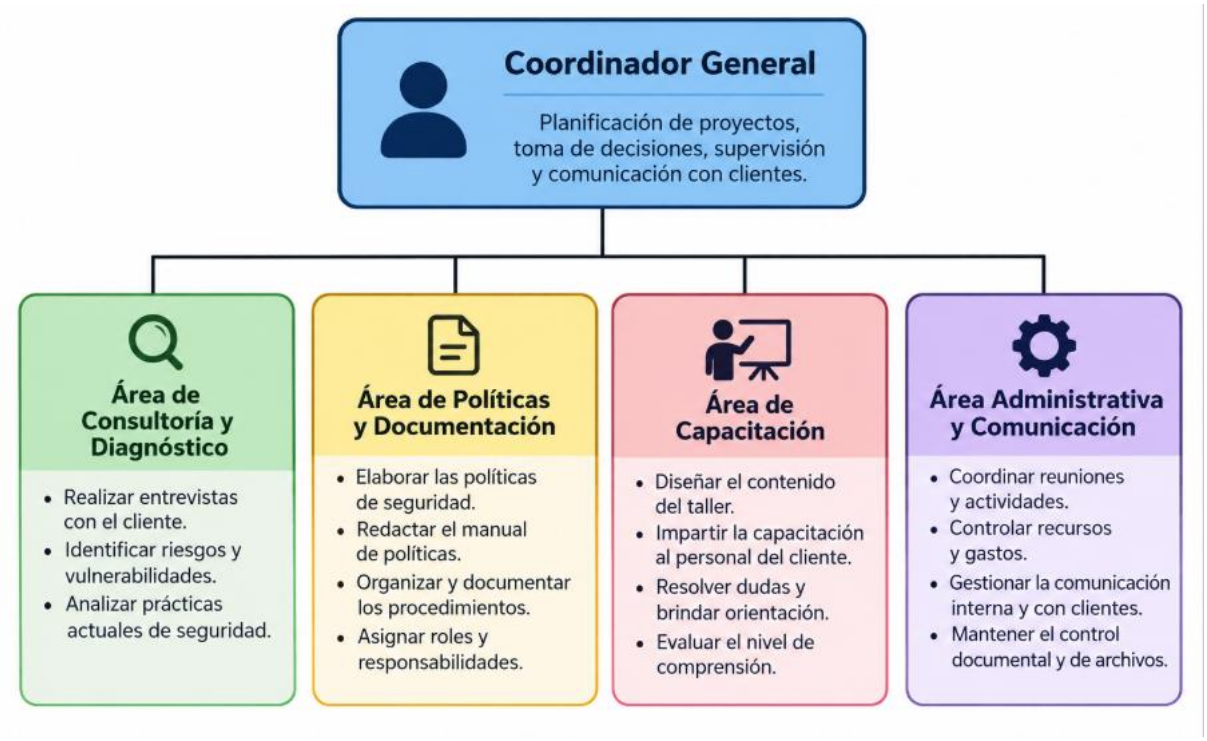
9.4 Jerarquía

Debido a que SecureInfo Consultores inicia como una microempresa de cinco integrantes, se utilizará una estructura organizacional sencilla.

La máxima autoridad será el Coordinador General, quien tendrá la responsabilidad de organizar los proyectos y mantener comunicación con los clientes. Debajo de este puesto se encontrarán los responsables de las diferentes áreas de trabajo.

9.5 Organigrama

La organización de la empresa se representa de la siguiente manera:



Cada integrante tendrá una función principal, pero podrá apoyar a las demás áreas cuando un proyecto lo requiera. De esta manera, se aprovechan mejor los recursos disponibles y se mantiene una estructura flexible.

9.6 Departamentos

9.6.1 Área de Consultoría y Diagnóstico

Será la encargada de tener el primer acercamiento con la situación del cliente. Realizará entrevistas, recopilar información e identificará posibles riesgos o vulnerabilidades relacionadas con el manejo de datos, contraseñas, dispositivos externos y accesos. Los resultados obtenidos servirán como base para determinar qué aspectos deben mejorarse.

9.6.2 Área de Políticas y Documentación

Tendrá la responsabilidad de elaborar las políticas de seguridad de acuerdo con las necesidades encontradas durante el diagnóstico. También organizará los procedimientos, responsabilidades y recomendaciones que formarán parte del Manual de Políticas de Seguridad que se entregará al cliente.

9.6.3 Área de Capacitación

Se encargará de preparar e impartir el taller dirigido al personal de la organización atendida. Su función será explicar las nuevas políticas de una manera clara y práctica, resolver dudas y orientar a los colaboradores sobre la forma correcta de aplicarlas en sus actividades diarias.

9.6.4 Área Administrativa y Comunicación

Tendrá a su cargo la coordinación de reuniones, organización de actividades, control básico de gastos y recursos, así como la comunicación con los clientes. También apoyará en el seguimiento de los proyectos para verificar que las actividades se desarrollen dentro de los tiempos establecidos.

9.7 Comunicación

La comunicación dentro de SecureInfo Consultores será clara, directa y organizada, con el propósito de que todos los integrantes conozcan sus responsabilidades y el avance de cada proyecto. Al ser una empresa pequeña, se facilitará el intercambio de información entre las diferentes áreas, permitiendo resolver dudas o inconvenientes de manera rápida.

Para la comunicación interna se utilizarán herramientas digitales como correo electrónico, mensajería instantánea, videollamadas y documentos compartidos. También se realizarán reuniones periódicas para revisar las actividades pendientes, distribuir tareas y verificar que se estén cumpliendo los tiempos establecidos.

La comunicación con los clientes tendrá un enfoque más formal y profesional. Se realizará principalmente por medio de correos electrónicos, reuniones presenciales o virtuales e informes de avance. Además, se establecerá una persona responsable de mantener el contacto con cada cliente, con el objetivo de evitar confusiones y asegurar que la información relacionada con el proyecto sea transmitida correctamente.

Debido a que la empresa trabajará con información sensible, también será importante mantener la confidencialidad en todas las comunicaciones y evitar compartir documentos o datos de los clientes con personas que no estén autorizadas.

9.8 Cultura Empresarial

En SecureInfo se busca un ambiente de trabajo basado en la responsabilidad, el respeto, la confianza y el trabajo en equipo. Es importante que exista apoyo entre los integrantes y que cada persona cumpla con las tareas que le corresponden para alcanzar los objetivos de cada proyecto.

Uno de los valores más importantes será la confidencialidad, ya que durante las consultorías se puede tener acceso a información interna de los clientes. Por esta razón, todos los integrantes deberán manejar los datos y documentos de manera responsable. También se promoverá el aprendizaje constante, debido a que la seguridad de la información es un área que cambia conforme aparecen nuevas tecnologías y riesgos.

9.9 Misión y Visión

9.9.1 Misión

Brindar servicios de consultoría en seguridad de la información que ayuden a las organizaciones a identificar riesgos, establecer políticas claras y mejorar la forma en que protegen y utilizan su información, ofreciendo un servicio accesible, responsable y adaptado a las necesidades de cada cliente.

9.9.2 Visión

Convertirse en la empresa de consultoría reconocida en Guatemala por asesorar pequeñas y medianas empresas, así como a entidades públicas, en el desarrollo de una cultura de seguridad de la información, ofreciendo soluciones prácticas y confiables.

9.10 Tecnología

La tecnología será una herramienta fundamental para el funcionamiento de SecureInfo Consultores, ya que gran parte de las actividades de la empresa se realizarán de manera digital. Para desarrollar los proyectos se utilizarán computadoras portátiles, conexión a Internet, correo electrónico y plataformas para realizar videollamadas y reuniones virtuales.

También se utilizarán herramientas para crear documentos, presentaciones, formularios y almacenar archivos en la nube. La información de cada cliente se mantendrá organizada en espacios separados y solamente podrán acceder a ella los integrantes que estén autorizados. Esto permitirá trabajar de una manera más ordenada y, al mismo tiempo, aplicar dentro de la empresa las medidas de seguridad que se recomiendan a los clientes.

9.11 Procedimientos y Políticas

SecureInfo Consultores tendrá procedimientos internos que servirán como guía para realizar las actividades de forma organizada y proteger la información que sea proporcionada por los clientes. Estas reglas deberán ser respetadas por todos los integrantes de la empresa.

- Entre las principales medidas se encuentran:
- Mantener la confidencialidad de la información de cada cliente.
- Utilizar contraseñas seguras y accesos individuales.
- Evitar el uso de dispositivos USB personales para guardar información de los proyectos.
- Realizar respaldos de los documentos importantes.
- Permitir el acceso a los archivos únicamente al personal que lo necesite.

- Solicitar autorización antes de compartir documentos o información del cliente.
- Mantener los archivos correctamente identificados y organizados.
- Informar cualquier situación que pueda representar un riesgo para la información.

Las políticas son importantes ya que la empresa debe comenzar por aplicar internamente las mismas buenas prácticas que posteriormente recomendará a sus clientes.

9.12 Número de Empleados

Durante su etapa inicial, SecureInfo Consultores estará conformada por cinco integrantes, quienes estarán distribuidos entre las diferentes áreas de la empresa. Cada integrante tendrá una responsabilidad principal, pero podrá colaborar en otras actividades cuando sea necesario.

Esta cantidad de personal es adecuada para comenzar, ya que el servicio se desarrolla por proyectos y no requiere una estructura demasiado grande. Además, permite mantener bajos los costos de operación. Si en el futuro aumenta la cantidad de clientes y proyectos, la empresa podrá incorporar más personal, principalmente en las áreas de consultoría, capacitación y administración.

9.13 Horarios

El horario general de atención de SecureInfo Consultores será de lunes a viernes de 8:00 a.m. a 5:00 p.m. Durante este horario se realizarán actividades administrativas, reuniones, elaboración de documentos, seguimiento de proyectos y atención a clientes.

Las visitas, entrevistas y capacitaciones se programarán previamente de acuerdo con la disponibilidad de cada organización. En algunos casos, los talleres podrán adaptarse al horario laboral del cliente para facilitar la participación de sus colaboradores.

Debido a que la empresa trabajará bajo una modalidad híbrida, algunas actividades como la elaboración de políticas, preparación de manuales y realización de informes podrán desarrollarse de manera remota. Esto brinda mayor flexibilidad al equipo y ayuda a reducir gastos de operación durante la etapa inicial de la empresa.

9.14 Metas

9.14.1 Corto plazo

- Atender los primeros clientes durante la etapa de introducción de la empresa.
- Completar el diagnóstico de riesgos de cada organización dentro de los primeros días del proyecto.
- Elaborar entre 5 y 7 políticas de seguridad personalizadas por cliente.
- Completar cada proyecto en un período aproximado de 20 días hábiles.

9.14.2 Mediano plazo

- Establecer una cartera estable de clientes conformada principalmente por PYMES y entidades públicas del Área Metropolitana de Guatemala.
- Desarrollar una metodología de trabajo estandarizada para los servicios de diagnóstico, diseño de políticas, capacitación y seguimiento.

- Fortalecer la reputación de SecureInfo mediante la calidad de los servicios y la satisfacción de los clientes.

- Incrementar progresivamente la cantidad de proyectos atendidos sin comprometer la calidad del servicio.

9.14.3 Largo plazo

- Posicionar a SecureInfo como una empresa reconocida en Guatemala por sus servicios accesibles en seguridad de la información.

- Ampliar la cobertura de servicios hacia otras organizaciones y regiones del país.

9.15 Principios

- Confidencialidad: Proteger y manejar responsablemente toda información proporcionada por los clientes.

- Responsabilidad: Cumplir los compromisos adquiridos, los tiempos establecidos y la calidad de los servicios ofrecidos.

- Integridad: Actuar de manera ética, transparente y profesional en todas las actividades de la empresa.

- Confianza: Generar relaciones duraderas con los clientes mediante servicios confiables y un manejo responsable de su información.

- Trabajo en equipo: Promover la colaboración y comunicación entre los integrantes para alcanzar los objetivos de cada proyecto.

- Innovación y aprendizaje continuo: Mantener una actitud de aprendizaje permanente ante la evolución de las tecnologías y los nuevos riesgos de seguridad.

- Prevención: Promover acciones anticipadas que permitan reducir riesgos y evitar incidentes relacionados con la información

X. Ingeniería del Proyecto

SecureInfo es una empresa de servicios de consultoría empresarial especializada en seguridad de la información. El núcleo del proyecto consiste en brindar asesoramiento profesional a micro, pequeñas y medianas empresas (PYMES) que carecen de un área técnica especializada, ayudándolas a proteger sus activos digitales más críticos.

Nuestra propuesta de Valor dentro de las empresas que nos contratan es el poder tener la información de sus clientes o proveedores de manera segura, en donde el flujo se maneje dentro de la misma, esto nos genera un valor agregado, al asesorar a los clientes, logramos que ellos generen confianza en sus clientes, en sus clientes potenciales hacen del saber que tienen manejo de la información confidencial y manejo seguro con sus empleados y entorno empresarial.

SecureInfo se creó con base en la necesidad que tienen las empresas en pleno crecimiento (microempresas, pequeñas, PYMES), en base a que las empresas se encuentran en crecimiento, no tienen un control definido, parámetros, reglas o normas que rigen el control de la información.

Al no tener la documentación y los requerimientos necesarios para el resguardo de la información sensible y las empresas al ver esta fuga de información confidencial optan por poder contratar un servicio de consultoría para agilizar el proceso y no perder clientes que saben que son potenciales.

Como Empresa de Servicios profesionales en seguridad de la información, se ofrecen al cliente los siguientes Paquetes:

- Diseño de Políticas: Dirigido a empresas que carecen de un marco normativo interno. Consiste en el mapeo, estructuración y redacción de políticas personalizadas para regular el acceso, uso y control de la información confidencial de los clientes y socios comerciales.

- Manuales de Procedimiento y Operación (SOP): Desarrollo de guías técnicas y operativas paso a paso para el manejo seguro de los datos. Este paquete garantiza la documentación integral de los procesos críticos de la empresa y la trazabilidad de las acciones, facilitando la creación de respaldos y la estandarización de tareas.

- Capacitación Personal: Programas de formación para los colaboradores enfocados en el manejo responsable de la información sensible y el uso correcto de los equipos de cómputo. El objetivo es instruir al personal en el cumplimiento normativo interno para mitigar errores humanos y evitar faltas administrativas o legales.

- Auditoría y Seguimiento: Evaluación periódica del uso de la infraestructura tecnológica para identificar vulnerabilidades y brechas de seguridad antes de que sean explotadas. Incluye un esquema de monitoreo y acompañamiento posterior para asegurar la correcta adopción de las medidas y garantizar la continuidad del negocio sin interrupciones operativas.

XI. Proceso de Producción

Para la ejecución de nuestros servicios en SecureInfo con el cliente, se seguirá un procedimiento establecido en 5 fases operativas, con un estimado de entrega total de 20 a 30 días.

Tabla 7

Procesos de cronograma a cliente

Fase	Etapa de la consultoría	Actividades Clave	Tiempo Estimado
Fase 1	Diagnóstico y Recopilación de Información.	Realizar entrevista con cliente. Auditoría técnica inicial Aprobación de presupuesto	Tiempo de entrega de 2 a 3 días hábiles.
Fase 2	Planificación y diseño de normativas.	Redacción de las políticas de seguridad. Elaboración de manuales de uso.	Tiempo de entrega de 9 a 12 días hábiles.
Fase 3	Implementación y Capacitación	Capacitación al personal Entrega de manuales y material para retroalimentación.	Tiempo de Entrega de 3 a 5 días hábiles.
Fase 4	Seguimiento de requerimientos	Realiza seguimiento de personal. Control de uso de las políticas.	Tiempo de entrega de 2 a 4 días hábiles.
Fase 5	Auditoría y Cierre de Servicio.	Entrega de reporte de las incidencias encontradas. Encuesta al personal.	Tiempo de entrega de 4 a 6 días hábiles.

Entrega de informe Final

Nota: Fases de cómo se trabaja con el cliente y los tiempos estipulados

XII. Flujograma Del Proyecto



XIII. TECNOLOGÌA DEL PROYECTO

SecureInfo desarrollará sus actividades mediante una serie de tareas organizadas que permitan utilizar adecuadamente las herramientas tecnológicas necesarias para brindar sus servicios de consultoría en seguridad de la información.

13.1 Identificación de las necesidades tecnológicas

Primero se determinarán las herramientas, equipos y recursos necesarios para realizar las actividades de la empresa, tomando en cuenta las necesidades de cada proyecto y los recursos disponibles.

Entre los principales recursos se encuentran:

- Computadoras portátiles.
- Conexión a Internet.
- Teléfonos celulares.
- Correo electrónico.
- Plataformas para videollamadas.
- Herramientas para elaborar documentos y presentaciones.
- Formularios digitales para recopilación de información.
- Servicios de almacenamiento en la nube.
- Plataformas de comunicación y mensajería.

- Dispositivos de respaldo institucional.

13.2 Selección y adquisición de herramientas

Se seleccionarán herramientas que sean accesibles, funcionales y adecuadas para las actividades de consultoría. Debido a que la empresa inicia como una microempresa, se priorizará el uso de herramientas gratuitas o de bajo costo que permitan reducir los gastos de operación.

El proyecto contempla el uso de Google Workspace o cuentas educativas, Meet, Word/Docs., Drive y formularios digitales.

13.3 Organización de los recursos tecnológicos

Los equipos y herramientas serán organizados de acuerdo con las funciones de cada integrante de la empresa. Cada persona tendrá responsabilidades específicas, pero podrá apoyar a otras áreas cuando sea necesario.

Los archivos de los clientes se almacenarán de forma organizada y separada, permitiendo el acceso únicamente al personal autorizado.

13.4 Uso de la tecnología para la comunicación

La tecnología permitirá mantener una comunicación rápida y ordenada entre los integrantes de SecureInfo y con los clientes.

Se utilizarán:

- Correo electrónico para comunicaciones formales.

- Mensajería instantánea para asuntos operativos.

- Videollamadas para reuniones y capacitaciones.
- Documentos compartidos para trabajar de manera colaborativa.
- Informes digitales para comunicar avances y resultados.

En la comunicación interna se utilizará el correo electrónico, mensajería instantánea, videollamadas y documentos compartidos, mientras que con los clientes se utilizarán principalmente correos, reuniones presenciales o virtuales e informes de avance.

13.5 Uso de inteligencia artificial

La inteligencia artificial podrá utilizarse como una herramienta de apoyo para optimizar determinadas actividades, como la organización de información, generación de ideas, elaboración de borradores, preparación de materiales de capacitación y apoyo en la documentación.

Su utilización deberá realizarse de manera responsable, evitando introducir información confidencial de los clientes en herramientas de IA que no estén autorizadas. La información sensible deberá mantenerse protegida y bajo los controles establecidos por la empresa.

13.6 Optimización del trabajo en equipo

Las herramientas digitales permitirán que los integrantes trabajen de manera colaborativa, incluso cuando se encuentren trabajando de forma remota.

El uso de documentos compartidos, almacenamiento en la nube y plataformas de comunicación permitirá:

- Compartir información de manera rápida.

- Evitar la duplicación de documentos.
- Coordinar actividades.
- Dar seguimiento a las tareas.
- Mantener actualizada la información de los proyectos.
- Facilitar la comunicación entre las diferentes áreas.

13.7 Protección y respaldo de la información

Debido a que SecureInfo trabaja directamente con información sensible, todos los recursos tecnológicos deberán utilizarse aplicando medidas de seguridad.

Entre las acciones principales se encuentran:

- Utilizar contraseñas seguras.
- Mantener accesos individuales.
- Restringir el acceso a personas autorizadas.
- Realizar respaldos de documentos importantes.
- Evitar utilizar dispositivos USB personales para información de los proyectos.
- Solicitar autorización antes de compartir información.
- Informar cualquier situación que pueda representar un riesgo.

Estas medidas forman parte de las políticas internas planteadas para SecureInfo.

13.8 Evaluación y mejora continua

Finalmente, se evaluará periódicamente si las herramientas utilizadas están permitiendo desarrollar las actividades de manera eficiente. Cuando se identifiquen dificultades, se podrán realizar ajustes, incorporar nuevas herramientas o modificar los procedimientos de trabajo.

De esta manera, la tecnología no solamente será utilizada para realizar las actividades de la empresa, sino también como un recurso para mejorar continuamente la productividad, comunicación, coordinación y seguridad de la información.

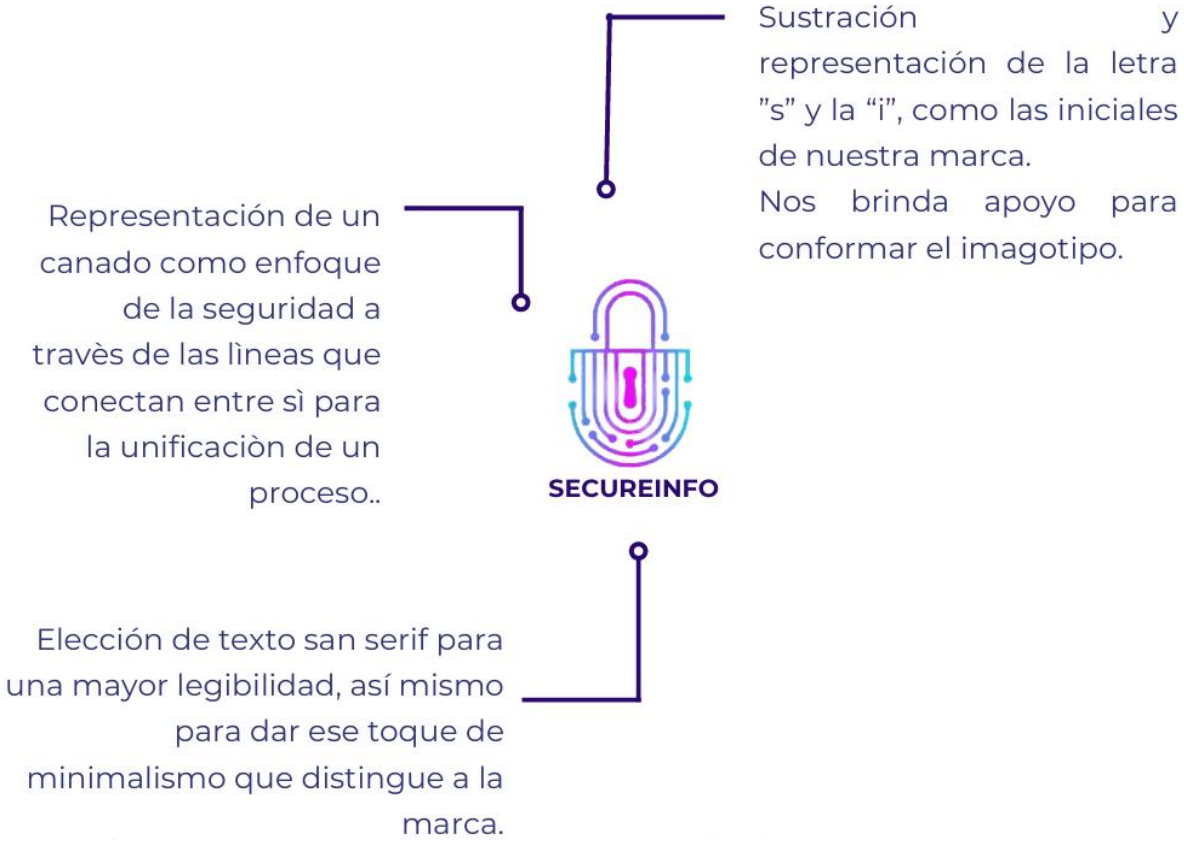
XIV. Manual de Marca

14.1 ¿Cómo nació SecureInfo?

Nace de la combinación de dos conceptos fundamentales que representan la esencia de la empresa: SECURE, relacionado con seguridad y protección, e INFO, relacionado con información. La unión de ambos conceptos da origen a un nombre corto, moderno y fácil de recordar, que comunica de manera directa el propósito de la empresa: proteger la información y ayudar a las organizaciones a gestionarla de forma segura. El nombre fue elegido porque la información se ha convertido en uno de los recursos más importantes para cualquier organización. Por ello, SECUREINFO busca transmitir desde su propio nombre una idea de protección, prevención y confianza, pero utilizando una identidad sencilla y cercana. De esta manera, SECUREINFO no representa únicamente seguridad informática, sino una propuesta orientada a proteger la información, prevenir riesgos y crear una cultura de seguridad dentro de las organizaciones

14.2 Logotipo

LOGOTIPO El logotipo de la marca fue creado a partir de la retórica visual Sinécdoque, en la que su construcción tiene una conexión inherente o una vinculación intrínseca de una figura de un candado a partir de líneas que conectan el asimismo de la tecnología junto a una tipografía de fácil comprensión. Lo que comunica a SECUREINFO es un alto dominio en la Tecnología, la innovación, la conectividad y claridad para ejecutar los procesos y sobre todo el dinamismo para implementar y ejecutar una idea.



14.3 Espacio de Seguridad

El espacio de seguridad del logotipo es de 1 cm a partir del límite de este. Se debe respetar este espacio para asegurar la óptima utilización y aplicación del logo dentro de los distintos espacios donde se implementará.



14.4 Tamaño Mínimo

El tamaño mínimo del logotipo para su reproducción es de 120 px de alto. No obstante, se recomienda para su utilización en sitios web e impresiones sea de 250 px de alto.



14.5 Paleta de Colores

El color sirve para influir en la conducta de los consumidores y, asimismo, incentivar las ventas. Un tono bien elegido ayuda a crear una imagen atractiva y profesional, así como transmitir los valores de la empresa. El Navy es el color dominante para la marca. Esta se asocia con nuestras sólidas raíces del profesionalismo, tecnología, confianza y protección, conceptos centrales que aporta la empresa. Por su parte el Magenta eléctrico representa la innovación, creatividad y transformación digital. Su tonalidad vibrante aporta una personalidad juvenil y moderna a la marca, diferenciándola de las empresas tradicionales del sector de seguridad de la información. El cian/turquesa brillante, Representa tecnología, innovación, claridad y conectividad. Su tonalidad vibrante transmite una imagen fresca, moderna y dinámica, asociada con el mundo digital y con soluciones tecnológicas accesibles.



14.6 Tipografía



14.7 ¿Quiénes Somos?

Una empresa guatemalteca especializada en seguridad de la información que ayuda a organizaciones a proteger y gestionar mejor su información. Trabajamos en la identificación de riesgos, creación de políticas de seguridad, elaboración de procedimientos y capacitación del personal, ofreciendo soluciones prácticas y adaptadas a las necesidades de cada organización. Convertimos la seguridad de la información en reglas claras, buenas prácticas y una cultura de prevención

XV. Caso de Implementación de Servicio

15.1 Entidad Solicitante

Banco Cooperativo del Sur, S.A.

15.1.1 Descripción Institucional.

El Banco Cooperativo del Sur, S.A. es una institución financiera privada fundada en 2023, que actualmente cuenta con 38 empleados distribuidos en dos sedes: la Oficina Central ubicada en la zona 9 de la Ciudad de Guatemala y una Sucursal en la zona 1 de Quetzaltenango. Su oferta de servicios incluye ahorro, créditos de consumo, transferencias y banca en línea básica, y su misión es ofrecer servicios financieros accesibles y seguros para la pequeña y mediana empresa en el occidente del país, con la visión de ser el banco cooperativo líder en innovación y confianza para el año 2030.

15.1.2 Antecedentes y Situación Actual

El banco inició operaciones en 2023 con una sola sede y 15 empleados. Debido a su rápido crecimiento, en 2025 abrió una segunda sede y contrató 23 personas más, alcanzando los 38 empleados. Cuenta con un pequeño sistema de seguridad perimetral (firewall, antivirus y respaldos básicos) que, hasta la fecha, ha sido efectivo contra amenazas externas. Sin embargo, el crecimiento acelerado ha traído consigo fugas de información de origen interno, que no han podido contener con las herramientas actuales. Por esta razón, la gerencia decidió contratar un servicio de consultoría informática externa para diagnosticar, proponer e implementar políticas de seguridad de la información.

INFORME FINAL

XVI. Índice

Implementación de Políticas de Seguridad de la Información 28

Reunión inicial 28

Cronograma 28

Presupuesto de Servicios de Consultoría Informática29

Notas del presupuesto: 29

Aprobación de Presupuesto 30

Documento de Aprobación de Presupuesto 30

Revisión de Equipos y Registro de incidentes 30

Uso de Dispositivos USB Personales.31

Contraseñas Débiles y Compartidas. 31

Reenvío de Información Sensible a Correos Externos. 31

Falta de respaldos actualizados. 31

Registro de incidentes. 31

Conclusión del diagnóstico. 32

Entrevistas al Personal 32

Hallazgos Principales 32

Identificación de Debilidades 33

Políticas de Seguridad de la Información 34

Política 001 34

Política 002 34

Política 003 35

Política 004 35

Política 005 36

Manual de Políticas de Seguridad de la Información 36

Capacitación al Personal 37

Objetivo de la Capacitación. 37

Agenda desarrollada. 37

Materiales Entregados. 37

Participación y Reacciones del Personal. 38

Resultados de la capacitación. 38

Conclusión de la capacitación. 38

Monitoreo de Cumplimiento 38

Metodología. 38

Hallazgos principales. 39

Resultados del Monitoreo. 39

Conclusión del Monitoreo. 40

Reporte de Incidentes 40

Incidentes Previos a la Consultoría Informática 40

Incidentes Detectados Durante el Monitoreo. 41

Comparativa Antes y Después de la Consultoría Informática 41

Conclusiones del Reporte 42

Encuesta de Satisfacción al Personal 42

Preguntas y resultados 42

Resumen general de la encuesta 43

Comentarios abiertos destacados 43

Conclusión de la encuesta 44

Recomendaciones 44

Mantener las auditorías periódicas. 44

Repetir la capacitación anualmente. 44

Actualizar las políticas según la evolución tecnológica. 44

Implementar autenticación de dos factores (2FA) 44

Fomentar una cultura de seguridad 44

XVII. Implementación de Políticas de Seguridad de la Información

17.1 Reunión inicial

El día 19 de enero de 2026, se llevó a cabo una reunión inicial entre el equipo de SecureInfo y el encargado del área de Tecnología de la Información del Banco Cooperativo del Sur, S.A., el Ing. Carlos Mendoza. El objetivo de la reunión fue conocer la situación actual de la entidad, entender sus preocupaciones respecto a la seguridad de la información y establecer el alcance del servicio de consultoría informática. Durante la reunión, el Ing. Mendoza manifestó que, a pesar de contar con un sistema de seguridad perimetral básico, el crecimiento acelerado del banco ha traído consigo incidentes internos que no han podido controlar. Se acordó realizar un diagnóstico exhaustivo para identificar las debilidades y priorizar las acciones correctivas.

17.2 Cronograma

Tabla 8

Cronograma con cliente

No.	Fase/Tarea	Inicio	Fin
1	Inicio	19-ene	19-ene
1.1	Reunión inicial y aprobación de presupuesto.	19-ene	19-ene
2	Planificación Y Diagnóstico	20-ene	23-ene
2.1	Revisión de equipos y registro de incidentes	20-ene	22-ene

2.2	Entrevistas al personal	21-ene	22-ene
2.3	Identificación de debilidades	23-ene	23-ene
3	Desarrollo	26-ene	06-feb
3.1	Diseño de las 5 políticas de seguridad	26-ene	30-ene
3.2	Redacción del manual de políticas de seguridad de la información	02-feb	06-feb
4	Ejecución	06-feb	06-feb
4.1	Capacitación al personal	06-feb	06-feb
4.2	Entrega de manuales y material didáctico	06-feb	06-feb
5	Seguimiento Y Cierre	09-feb	13-feb
5.1	Monitoreo de cumplimiento (5 días)	09-feb	13-feb
5.2	Reporte de incidentes	13-feb	13-feb
5.3	Encuesta de satisfacción al personal	13-feb	13-feb
5.4	Entrega de informe final y cierre	13-feb	13-feb

Nota: entrega de cronograma a cliente

17.3 Presupuesto de Servicios de Consultoría Informática

Tabla 9

Presupuesto de consultoría

No.	Etapas	Descripción	Cantidad	Precio Unitario	Subtotal
1	Diagnóstico inicial	Reunión con el encargado de TI, entrevistas al personal, revisión de equipos y evaluación de debilidades.	1	Q2,500.00	Q2,500.00
2	Diseño de políticas de seguridad	Redacción de 5 políticas: uso de dispositivos externos, contraseñas, manejo de correo, respaldos y acceso a datos.	5	Q800.00	Q4,000.00
3	Manual de políticas	Documento formal con todas las políticas, procedimientos y roles.	1	Q2,500.00	Q2,500.00
4	Capacitación al personal	Taller de 2 horas para 20 empleados.	1	Q3,500.00	Q3,500.00

5	Seguimiento y monitoreo	Monitoreo durante 5 días, reporte de incidentes y encuesta de satisfacción al personal.	1	Q2,500.00	Q2,500.00
Total					Q15,000.00

Nota: Entrega de Presupuesto a cliente en consideración del trabajo a realizar

17.4 Notas del presupuesto:

· Forma de pago: 50% (Q7,500.00) al finalizar el diagnóstico inicial (23 de enero) y 50% (Q7,500.00) contra entrega del manual y realización del taller (06 de febrero).

· Validez de la oferta: 15 días calendario a partir de la fecha de presentación.

· No incluye: Implementación técnica de software, adquisición de hardware, auditoría posterior ni servicios legales externos.

· Total, en letras: Quince mil quetzales exactos.

XVIII. Aprobación de Presupuesto

El día 19 de enero de 2026 se llevó a cabo una segunda reunión entre el equipo de SecureInfo y la gerencia del Banco Cooperativo del Sur, S.A., con el objetivo de presentar formalmente el presupuesto correspondiente al servicio de consultoría informática en políticas de seguridad de la información. Durante la reunión se expuso el desglose por etapas, los entregables

y el monto total de Q15,000.00. La gerencia, tras revisar la propuesta y considerar los beneficios esperados, aprobó el presupuesto en su totalidad.

XIX. Documento de Aprobación de Presupuesto

Tabla 10

Aprobación del cliente al presupuesto

BANCO COOPERATIVO DEL SUR, S.A.	
Fecha	19 de enero de 2026
Aprobación de Presupuesto de Consultoría Informática	
Descripción	Presupuesto presentado por SecureInfo por un monto total de Q15,000.00, que cubre: diagnóstico inicial, diseño de políticas de seguridad, manual de políticas, capacitación al personal y seguimiento por 5 días.
Monto Total	Q15,000.00 (Quince mil quetzales exactos)
Comentarios	El desglose presentado refleja las necesidades detectadas durante el diagnóstico inicial y se alinea con los objetivos de fortalecer la seguridad de la información del banco. La distribución de costos por etapa se considera adecuada y transparente.
Elaborado por	

Nombre	Ing. Carlos Mendoza
Cargo	Encargado de TI
Aprobado por	
Nombre	Lic. Patricia Gutiérrez
Cargo	Gerente General

XX. Revisión de Equipos y Registro de incidentes

Durante el 20 al 23 de enero de 2026, el equipo de SecureInfo realizó el diagnóstico inicial en las instalaciones del Banco Cooperativo del Sur, S.A. Las actividades incluyeron una reunión con el encargado de TI, Ing. Carlos Mendoza; la revisión física y lógica de los equipos; la entrevista a ocho empleados de distintas áreas; y el análisis del registro de incidentes documentado por la gerencia.

Como resultado de la revisión de equipos, se identificaron las siguientes debilidades, que explican directamente los incidentes ocurridos.

20.1 Uso de Dispositivos USB Personales.

Se encontró que los equipos de las áreas de créditos y tesorería tienen los puertos USB habilitados sin ninguna restricción. No existe una política que prohíba la conexión de dispositivos externos ni un control técnico que los bloquee. Durante la revisión, se detectó en el equipo de un analista de créditos un archivo malicioso proveniente de una memoria USB personal, el cual no

fue bloqueado por el antivirus porque la configuración de protección en tiempo real estaba desactualizada. Esto explica la propagación del malware y la pérdida de 15 expedientes.

20.2 Contraseñas Débiles y Compartidas.

La revisión de las cuentas de usuario reveló que el sistema no exige requisitos mínimos de complejidad: no hay longitud mínima, no se solicitan mayúsculas, números ni símbolos, y las contraseñas nunca expiran. Se encontraron múltiples cuentas con claves como "123456" o "banco2025". Además, los registros de acceso mostraron inicios de sesión desde ubicaciones inusuales, lo que confirma que las credenciales fueron compartidas o vulneradas. Esto permitió la manipulación indebida de 8 cuentas de ahorro.

20.3 Reenvío de Información Sensible a Correos Externos.

Al revisar el servidor de correo institucional, se verificó que no existe ninguna regla de prevención de fuga de datos (DLP) ni restricción para el reenvío de archivos adjuntos a cuentas externas. El empleado de tesorería pudo enviar sin obstáculos un archivo con saldos y movimientos financieros a su correo personal. El sistema no generó alerta ni bloqueo alguno. Esto coincide con el incidente reportado y confirma la ausencia de controles sobre la salida de información.

20.4 Falta de respaldos actualizados.

La revisión del sistema de respaldo mostró que estos se realizan de forma manual, sin una programación automática. No existe una copia diaria ni una política de retención. El último respaldo disponible tenía tres días de antigüedad, lo que coincidió con el corte de energía que provocó la pérdida de transacciones. Esto evidencia la necesidad de un respaldo automático diario en la nube institucional.

20.5 Registro de incidentes.

El banco cuenta con un registro básico de incidentes, en el cual se documentaron los cuatro casos descritos en los antecedentes. La revisión de este registro permitió confirmar las fechas, los responsables involucrados y el impacto económico y reputacional de cada evento. Los incidentes ocurrieron entre noviembre y diciembre de 2025, y aunque la gerencia intentó contenerlos con acciones aisladas, no se implementaron políticas formales ni controles permanentes.

20.6 Conclusión del diagnóstico.

La revisión de equipos y el análisis de los incidentes confirman que las debilidades identificadas son de carácter estructural: no existen políticas de seguridad, los controles técnicos son mínimos y el personal no ha sido capacitado.

XXI. Entrevistas al Personal

Durante el 21 al 22 de enero de 2026, el equipo de SecureInfo realizó entrevistas individuales a empleados de distintas áreas del Banco Cooperativo del Sur, S.A.

En total, se realizaron 8 entrevistas con una duración promedio de 30 minutos cada una, distribuidas entre las áreas de créditos, tesorería, atención al cliente, operaciones y recursos humanos. Todas se llevaron a cabo de forma presencial en las instalaciones del banco, con previo consentimiento de la gerencia y garantizando la confidencialidad de las respuestas.

21.1 Hallazgos Principales

Las entrevistas revelaron patrones de conducta y percepciones que explican, desde la perspectiva del personal, por qué ocurren los incidentes.

21.1.1 Uso de Dispositivos Externos

La mayoría de los empleados entrevistados admitió haber conectado memorias USB personales a los equipos institucionales en algún momento, principalmente para "pasar archivos rápido" o "llevar trabajo a casa". Ninguno sabía que esto estaba prohibido (porque no existe una política formal), y varios desconocían que una USB puede contener malware. El analista de créditos involucrado en el Caso de “Uso de Dispositivos USB Personales” comentó: "Yo solo la usé para pasar unos documentos, no sabía que podía infectar la computadora". Esta falta de conciencia es un factor clave en la propagación de virus.

21.1.2 Contraseñas y Acceso

Los cajeros y analistas entrevistados confesaron que comparten sus contraseñas con compañeros de confianza para "no perder tiempo" cuando alguien se ausenta. También admitieron usar contraseñas fáciles de recordar, como fechas de cumpleaños o nombres de familiares, porque el sistema no les exige cambiarlas ni usar caracteres especiales. La encargada de Recursos Humanos señaló: "Nunca nos han dicho cómo crear una contraseña segura, cada quien hace lo que puede". Esto confirma la necesidad de una política de contraseñas robusta.

21.1.3 Manejo de Correo Electrónico

El encargado de tesorería, involucrado en el Caso “Reenvío de Información Sensible a Correos Externos”, explicó que reenvió el archivo a su correo personal porque "necesitaba trabajar en casa y no tenía acceso remoto al sistema". No sabía que estaba prohibido (no existe tal prohibición) ni que su acción podía poner en riesgo la información. Los demás entrevistados

manifestaron que nunca han recibido capacitación sobre qué información se puede compartir y qué no. Esto evidencia la ausencia de una política de manejo de correo.

21.1.4 Respaldos y Pérdida de información

El encargado de operaciones, responsable de los respaldos, admitió que estos se hacen "cuando hay tiempo" y que no existe un procedimiento establecido. Comentó: "A veces se me olvida, o no alcanzo, y lo dejo para el día siguiente". Esto explica por qué el último respaldo tenía tres días de antigüedad cuando ocurrió el corte de energía. El personal de operaciones desconoce la importancia de un respaldo diario y automático.

21.1.5 Percepción general del personal

La mayoría de los entrevistados coincidió en que el banco ha crecido muy rápido y que "nunca hubo tiempo de organizar las reglas". Varios expresaron preocupación por las fugas recientes y manifestaron estar dispuestos a cumplir nuevas políticas si se les explican bien. La encargada de Recursos Humanos resumió: "Nos hace falta orden, pero también nos hace falta que alguien nos enseñe cómo hacerlo".

21.1.6 Conclusión de las entrevistas

Las entrevistas confirman que las debilidades identificadas en la revisión de equipos no son solo técnicas, sino también humanas: el personal no tiene políticas claras, no ha sido capacitado y ha desarrollado prácticas inseguras por costumbre o desconocimiento.

XXII. Identificación de Debilidades

Del 20 al 23 de enero el equipo de consultoría informática realizó una revisión de los equipos, entrevistas al personal y análisis de los registros de incidentes. Como resultado, se identificaron cuatro debilidades.

Tabla 11

Debilidades encontradas en la empresa

Identificador	Área	Debilidad Detectada	Descripción	Nivel de Riesgo	Impacto potencial
001	Créditos y Tesorería	Uso de dispositivos USB personales	Se encontraron puertos USB habilitados sin restricción. Un analista de créditos conectó una memoria USB personal con malware; el antivirus tenía la protección en tiempo real desactualizada y no lo bloqueó.	Alto	Pérdida de 15 expedientes, pérdida de confidencialidad, daño reputacional y posibles sanciones legales.
002	Gestión de Usuarios	Contraseñas débiles y compartidas	El sistema no exige longitud mínima, mayúsculas, números ni símbolos, y las contraseñas no expiran. Se hallaron claves como "123456" o "banco2025" e inicios	Alto	Manipulación indebida de 8 cuentas de ahorro.

			de sesión desde ubicaciones inusuales.		
003	Tesorería	Reenvío de información sensible a correos externos	No existen reglas DLP ni restricción para reenviar adjuntos a cuentas externas. Un empleado de tesorería envió saldos y movimientos financieros a su correo personal y el sistema no alertó ni bloqueó.	Medio	Fuga de información financiera.
004	Operaciones	Falta de respaldos actualizados	Los respaldos son manuales, sin programación automática, sin copia diaria ni política de retención. El último respaldo tenía 3 días de antigüedad.	Medio	Pérdida de transacciones por corte de energía, retrasos operativos y costos de recuperación.

Nota: Identificación de las debilidades y creación de las políticas.

XXIII. Políticas de Seguridad de la Información

23.1 Política 001

23.1.1 Nombre de la política

Política de Uso de Dispositivos Externos

23.1.2 Objetivo

Prevenir la propagación de malware y la fuga de información mediante la regulación del uso de dispositivos de almacenamiento externo (memorias USB, discos duros portátiles, tarjetas SD, etc.) en los equipos institucionales del Banco Cooperativo del Sur, S.A.

23.1.3 Alcance

Aplica a todos los empleados, contratistas y proveedores que utilicen equipos institucionales o que accedan a la red del banco. Incluye computadoras de escritorio, laptops, servidores y cualquier dispositivo conectado a la red corporativa.

23.1.4 Encargado de la política

Oficial de Seguridad de la Información (CISO), en coordinación con el área de TI.

23.1.5 Fecha de vigencia y revisión

Vigente a partir del 7 de febrero de 2026. Revisión anual o cuando ocurran cambios significativos en la infraestructura tecnológica.

23.1.6 Lineamientos principales

- Queda prohibido conectar dispositivos USB personales a equipos institucionales sin autorización previa del área de TI.
- Solo se permitirán dispositivos externos proporcionados por el banco y previamente escaneados.

- El área de TI deberá deshabilitar los puertos USB en los equipos que no requieran su uso.
- Cualquier excepción deberá ser solicitada por escrito y aprobada por el CISO.

23.2 Política 002

23.2.1 Nombre de la política

Política de Contraseñas Seguras

23.2.2 Objetivo

Establecer los requisitos mínimos de complejidad, vigencia y manejo de contraseñas para garantizar que solo el personal autorizado acceda a los sistemas, bases de datos y cuentas de ahorro del banco.

23.2.3 Alcance

Aplica a todos los empleados, contratistas y proveedores que utilicen cuentas de usuario para acceder a los sistemas del Banco Cooperativo del Sur, S.A.

23.2.4 Encargado de la política

Oficial de Seguridad de la Información (CISO), en coordinación con el área de TI.

23.2.5 Fecha de vigencia y revisión

Vigente a partir del 7 de febrero de 2026. Revisión anual o cuando se detecten incidentes relacionados con accesos no autorizados.

23.2.6 Lineamientos principales

- Las contraseñas deben tener un mínimo de 8 caracteres e incluir mayúsculas, minúsculas, números y símbolos.
- Las contraseñas deben cambiarse cada 90 días.
- Queda prohibido compartir contraseñas con compañeros, supervisores o terceros.
- El sistema debe bloquear la cuenta tras 5 intentos fallidos de inicio de sesión.
- No se permite el uso de contraseñas como "123456", "banco2025" o datos personales fáciles de adivinar.

23.3 Política 003

23.3.1 Nombre de la política

Política de Manejo de Correo Electrónico

23.3.2 Objetivo

Prevenir la fuga de información sensible a través del correo electrónico institucional, regulando el envío, reenvío y almacenamiento de archivos adjuntos que contengan datos financieros, personales o estratégicos del banco.

23.3.3 Alcance

Aplica a todos los empleados, contratistas y proveedores que utilicen cuentas de correo institucional del Banco Cooperativo del Sur, S.A.

23.3.4 Encargado de la política

Oficial de Seguridad de la Información (CISO), en coordinación con el área de TI y Recursos Humanos.

23.3.5 Fecha de vigencia y revisión

Vigente a partir del 7 de febrero de 2026. Revisión anual o cuando se detecten incidentes de fuga de información.

23.3.6 Lineamientos principales

- Queda prohibido reenviar información sensible (saldos, movimientos financieros, expedientes de clientes, datos personales) a cuentas de correo externas sin autorización.
- El área de TI deberá implementar reglas de prevención de fuga de datos (DLP) en el servidor de correo.
- Todo envío de información sensible a terceros autorizados debe realizarse mediante canales cifrados.
- Los correos con información confidencial deben marcarse como "Confidencial" y eliminarse después de su uso.

23.4 Política 004

23.4.1 Nombre de la política

Política de Respaldo de Información

23.4.2 Objetivo

Garantizar la disponibilidad, integridad y recuperación de la información crítica del banco mediante la implementación de respaldos automáticos, periódicos y verificables, evitando la pérdida de datos ante incidentes técnicos o humanos.

23.4.3 Alcance

Aplica a todos los sistemas, bases de datos, servidores y equipos que contengan información crítica del Banco Cooperativo del Sur, S.A.

23.4.4 Encargado de la política

Oficial de Seguridad de la Información (CISO), en coordinación con el área de Operaciones y TI.

23.4.5 Fecha de vigencia y revisión

Vigente a partir del 7 de febrero de 2026. Revisión anual o cuando ocurran cambios en la infraestructura tecnológica.

23.4.6 Lineamientos principales

- Los respaldos deben realizarse de forma automática y diaria en la nube institucional.
- Debe existir una copia de respaldo semanal en un medio físico seguro y fuera de las instalaciones.
- Los respaldos deben verificarse mensualmente para asegurar que son recuperables.
- Se debe mantener un registro de las fechas, responsables y resultados de cada respaldo.

- La retención mínima de respaldos será de 90 días.

23.5 Política 005

23.5.1 Nombre de la política

Política de Acceso a Datos

23.5.2 Objetivo

Establecer los controles de acceso a la información sensible del banco, asegurando que solo el personal autorizado pueda consultar, modificar o eliminar expedientes de clientes, bases de datos y registros financieros.

23.5.3 Alcance

Aplica a todos los empleados, contratistas y proveedores que tengan acceso a bases de datos, expedientes o sistemas que contengan información confidencial del Banco Cooperativo del Sur, S.A.

23.5.4 Encargado de la política

Oficial de Seguridad de la Información (CISO), en coordinación con el área de TI y Recursos Humanos.

23.5.5 Fecha de vigencia y revisión

Vigente a partir del 7 de febrero de 2026. Revisión anual o cuando se detecten accesos no autorizados.

23.5.6 Lineamientos principales

- El acceso a datos se otorgará bajo el principio de "mínimo privilegio": cada empleado solo tendrá acceso a la información necesaria para realizar sus funciones.
- Los permisos de acceso deben ser aprobados por el jefe inmediato y el CISO.
- Toda modificación a bases de datos debe quedar registrada en un log de auditoría.
- Los accesos deben revisarse trimestralmente y revocarse cuando un empleado cambie de puesto o cese sus funciones.
- Queda prohibido el acceso a datos sin una justificación laboral verificable.

XXIV. Manual de Políticas de Seguridad de la Información

Como parte del paquete de consultoría informática, se elaboró el Manual de Políticas de Seguridad de la Información del Banco Cooperativo del Sur, S.A., el cual compila las cinco políticas diseñadas. Este documento constituye el entregable principal del servicio y sirve como guía oficial para el personal del banco.

Tabla 12

Manual de políticas para la empresa

Datos	Detalles
Nombre del Documento	Manual de Políticas de Seguridad de la Información
Versión	1.0
Fecha de Vigencia	7 de febrero de 2026

Elaborado Por	SecureInfo
Cantidad de Políticas	5
Formato	Digital (PDF) e impreso para el personal
Ubicación	Se anexa al presente informe como documento complementario

Nota: Creación de lineamientos para el adjunto del manual.

El manual fue entregado en formato digital e impreso, y se distribuyó a los 20 empleados durante el taller de capacitación. Su contenido incluye, para cada política: directrices, procedimiento de cumplimiento, excepciones, mecanismos de control, régimen de sanciones y plan de contingencia.

XXV. Capacitación al Personal

Fecha: 6 de febrero de 2026

Lugar: Sala de capacitación de la Oficina Central, Banco Cooperativo del Sur, S.A.

Duración: 2 horas (de 9:00 a 11:00 horas)

Dirigido a: 20 empleados de las áreas de créditos, tesorería, atención al cliente, operaciones y recursos humanos.

25.1 Objetivo de la Capacitación.

Dar a conocer las 5 políticas de seguridad de la información aprobadas, explicar su aplicación práctica en las actividades diarias y fomentar una cultura de seguridad dentro del banco.

25.2 Agenda desarrollada.

Tabla 13

Agenda para trabajar con cliente

Hora	Actividad	Responsable
9:00 – 9:15	Bienvenida y presentación de SecureInfo.	Equipo consultor
9:15 – 9:45	Presentación de las 5 políticas: objetivos, alcance y lineamientos.	Consultor Senior
9:45 – 10:15	Casos prácticos: análisis de los 4 incidentes ocurridos y cómo las políticas los previenen.	Consultor Junior
10:15 – 10:45	Taller participativo: dinámica de preguntas y respuestas, resolución de dudas.	Equipo consultor
10:45 – 11:00	Entrega del manual impreso y cierre	Equipo consultor

Nota: Entrega de Cronograma para la capacitación de personal

25.3 Materiales Entregados.

- Manual de Políticas de Seguridad de la Información (versión impresa y digital).

- Formulario de acuerdo de confidencialidad para firma de los empleados.

Participación y Reacciones del Personal.

- Los 20 empleados convocados asistieron puntualmente.
- Durante la presentación, varios empleados manifestaron que desconocían los riesgos de conectar USB personales y que nunca habían recibido una capacitación similar.
- El encargado de tesorería, involucrado en el incidente de reenvío de correo, compartió su experiencia y recomendó a sus compañeros seguir las nuevas políticas.
- La encargada de Recursos Humanos agradeció la iniciativa y propuso que la capacitación se repita cada año para el personal de nuevo ingreso.

25.4 Resultados de la capacitación.

- Asistencia: 20 de 20 empleados convocados (100%).
- Encuesta de satisfacción: Al finalizar el taller, se aplicó una encuesta anónima. El 85% de los participantes calificó la capacitación como "excelente" y el 15% como "buena". El 90% consideró que las políticas son claras y aplicables a su trabajo diario.
- Compromiso: Todos los empleados firmaron el acuerdo de confidencialidad y se comprometieron a cumplir las políticas a partir de su vigencia (7 de febrero de 2026).

25.5 Conclusión de la capacitación.

La jornada de capacitación cumplió con su objetivo: informar, concientizar y comprometer al personal con las nuevas políticas de seguridad. La alta participación y las respuestas positivas reflejan una actitud receptiva hacia la mejora de la seguridad de la información en el banco.

XXVI. Monitoreo de Cumplimiento

26.1 Período

9 al 13 de febrero de 2026

26.2 Responsables

SecureInfo, en coordinación con el Ing. Carlos Mendoza (TI) y el CISO del banco.

26.3 Objetivo

Verificar la aplicación efectiva de las 5 políticas de seguridad durante los primeros 5 días posteriores a su entrada en vigencia, identificar desviaciones y aplicar acciones correctivas inmediatas.

26.4 Metodología.

Durante los 5 días, el equipo de consultoría informática realizó las siguientes actividades de monitoreo:

- Revisión Diaria de Logs. Se analizaron los registros de conexión USB, inicios de sesión, envíos de correo y accesos a bases de datos.
- Auditorías Sorpresa. Se inspeccionaron aleatoriamente 5 equipos por día para verificar el cumplimiento de las políticas de contraseñas, USB y acceso a datos.

- Entrevistas Breves. Se conversó con 3 empleados por día para confirmar que conocían y aplicaban las políticas.

- Verificación de respaldos. Se revisó que el respaldo automático diario se ejecutara correctamente y que la copia física semanal se realizara según lo planificado.

- Registro de incidentes. Se documentaron todos los eventos relacionados con las políticas, incluyendo intentos de incumplimiento.

26.5 Hallazgos principales.

Tabla 14

Hallazgos después de la capacitación

Día	Hallazgo	Política Involucrada	Acción Tomada
Lunes 9-feb	Un empleado de créditos intentó conectar una USB personal. El sistema generó una alerta automática y el puerto ya estaba deshabilitado.	001 – Dispositivos externos	Se le recordó la política y se le pidió usar el canal autorizado. No hubo daño.
Martes 10-feb	Se detectó que una cuenta aún tenía una contraseña antigua ("banco2025"). El sistema la marcó como expirada.	002 – Contraseñas seguras	El empleado cambió la contraseña inmediatamente.

Miércoles 11-feb	Un correo con información financiera intentó ser enviado a una cuenta externa. El sistema DLP lo bloqueó.	003 – Manejo de correo	Se notificó al CISO y se capacitó al empleado nuevamente.
Jueves 12-feb	El respaldo automático se ejecutó sin problemas. La copia física semanal se realizó y se guardó en la caja de seguridad.	004 – Respaldo de información	Sin observaciones.
Viernes 13-feb	Se revisaron los accesos a bases de datos. No se detectaron accesos no autorizados. Los permisos estaban correctamente asignados.	005 – Acceso a datos	Sin observaciones.

Nota: Recolección de la información para visualizar comportamientos anómalos

26.6 Resultados del Monitoreo.

- Cumplimiento general. El 95% de los empleados cumplió con las políticas desde el primer día.
- Incidentes. Se detectaron 3 intentos de incumplimiento (USB, contraseña y correo), todos fueron bloqueados o corregidos de inmediato sin consecuencias graves.

- Efectividad de los controles. Las alertas automáticas y los bloqueos del sistema funcionaron correctamente.

- Percepción del personal. En las entrevistas, los empleados manifestaron sentirse más seguros y conscientes de los riesgos. La mayoría consideró que las políticas son claras y fáciles de seguir.

26.7 Conclusión del Monitoreo.

Los primeros 5 días de vigencia de las políticas demuestran una adopción positiva por parte del personal. Los pocos incidentes detectados fueron manejados rápidamente gracias a los controles implementados y a la capacitación previa. El banco ahora cuenta con un sistema de seguridad más robusto y con personal comprometido con su cumplimiento. Se recomienda continuar con auditorías periódicas y repetir la capacitación anualmente.

XXVII. Reporte de Incidentes

Fecha de emisión: 13 de febrero de 2026

Período cubierto: noviembre 2025 – febrero 2026

Elaborado por: SecureInfo, en coordinación con el CISO del Banco Cooperativo del Sur, S.A.

Objetivo: Documentar de forma cronológica todos los incidentes de seguridad de la información ocurridos en el banco antes y después de la implementación de las políticas, con el fin de evidenciar el impacto de la consultoría informática y sentar las bases para futuras auditorías.

27.1 Incidentes Previos a la Consultoría Informática

Estos son los cuatro casos que motivaron la contratación de SecureInfo. Ocurrieron antes de que existieran políticas formales de seguridad.

Tabla 15

Incidentes antes de las políticas creadas

No.	Fecha	Incidente	Área	Consecuencia	Política que lo Previene
1	Nov 2025	Conexión de USB personal con malware	Créditos	Pérdida de 15 expedientes	001 – Dispositivos externos
2	Nov 2025	Contraseñas débiles y compartidas	Gestión de usuarios	Manipulación de 8 cuentas de ahorro	002 – Contraseñas seguras
3	Dic 2025	Reenvío de información sensible a correo externo	Tesorería	Fuga de información financiera	003 – Manejo de correo
4	Dic 2025	Falta de respaldos actualizados	Operaciones	Pérdida de 3 días de transacciones	004 – Respaldo de información
Total, de incidentes previos			4		

Impacto	Pérdida de información, daño reputacional y riesgo legal

Nota: entrega de las políticas y que vulnerabilidades se protege la empresa.

27.2 Incidentes Detectados Durante el Monitoreo.

Durante los 5 días de monitoreo posterior a la entrada en vigencia de las políticas, se detectaron 3 intentos de incumplimiento. Ninguno causó daño, gracias a los controles implementados.

Tabla 16

Errores encontrados por los empleados

No.	Fecha	Incidente	Área	Consecuencia	Política que lo Previene
1	9-feb	Intento de conectar USB personal.	Créditos	El puerto ya estaba deshabilitado y el sistema generó alerta. Se recordó la política al empleado.	Sin daño
2	10-feb	Contraseña antigua aún activa ("banco2025").	Gestión de usuarios	El sistema la marcó como expirada y el empleado la cambió de inmediato.	Sin daño

3	11-feb	Intento de enviar correo con información financiera a cuenta externa.	Tesorería	El sistema DLP bloqueó el envío y se notificó al CISO. El empleado recibió refuerzo de capacitación.	Sin daño
Total, de incidentes durante el monitoreo				3	
Impacto				Ninguno. Todos fueron bloqueados o corregidos de inmediato.	

Nota: Reporte de los incidentes encontrados después de la capacitación.

27.3 Comparativa Antes y Después de la Consultoría Informática

Tabla 17

Comparativa del antes y después de las politicas

Aspecto	Antes	Después
Incidentes con daño	4	0
Pérdida de información	Sí (15 expedientes, 8 cuentas, 3 días de transacciones)	No
Controles preventivos	Ninguno	5 políticas + alertas automáticas + DLP
Personal capacitado	No	20 empleados (100%)

Capacidad de respuesta	Reactiva y desorganizada	Inmediata y documentada

Nota: comparativas de los incidentes que se presentaban en la empresa.

27.4 Conclusiones del Reporte

27.4.1 Antes de la Consultoría Informática

El banco no contaba con políticas formales, controles técnicos ni personal capacitado. Los 4 incidentes ocurridos causaron pérdidas económicas y de información.

27.4.2 Después de la Consultoría Informática

Las 5 políticas entraron en vigencia, el personal fue capacitado y los controles automáticos funcionaron. Los 3 intentos de incumplimiento fueron bloqueados sin consecuencias.

27.4.3 Recomendación

Mantener las auditorías periódicas, repetir la capacitación anualmente y actualizar las políticas según la evolución tecnológica del banco.

XXVIII. Encuesta de Satisfacción al Personal

Fecha de aplicación: 13 de febrero de 2026

Dirigido a: 20 empleados del Banco Cooperativo del Sur, S.A.

Método: Encuesta anónima, aplicada de forma digital al finalizar el período de monitoreo.

Objetivo: Medir el nivel de satisfacción del personal respecto a las políticas implementadas, la capacitación recibida y el acompañamiento de SecureInfo durante el proyecto.

28.1 Preguntas y resultados

1. ¿Cómo califica la claridad de las políticas implementadas?

Opción	Respuesta	Porcentaje
Excelente	14	70%
Buena	5	25%
Regular	1	5%
Mala	0	0%

2. ¿Considera que las políticas son aplicables a su trabajo diario?

Opción	Respuesta	Porcentaje
Sí, totalmente	16	80%
Sí, en su mayoría	3	15%
Parcialmente	1	5%

No	0	0%

3. ¿Cómo evalúa la capacitación recibida?

Opción	Respuesta	Porcentaje
Excelente	15	75%
Buena	5	25%
Regular	0	0%
Mala	0	0%

4. ¿Se sintió acompañado por el equipo de SecureInfo durante el proyecto?

Opción	Respuesta	Porcentaje
Sí, en todo momento	18	90%
Sí, la mayoría del tiempo	2	10%
Poco	0	0%

No	0	0%

5. ¿Cómo percibe la seguridad de la información del banco después de la implementación?

Opción	Respuesta	Porcentaje
Mucho más segura	17	85%
Más segura	3	15%
Igual	0	0%
Menos segura	0	0%

6. ¿Recomendaría este servicio de consultoría Informática a otra entidad?

Opción	Respuesta	Porcentaje
Sí, definitivamente	19	95%
Probablemente sí	1	5%
No	0	0%

28.2 Resumen general de la encuesta

Indicador	Resultado
Satisfacción general	95%
Claridad de las políticas	95%
Aplicabilidad	95%
Calidad de la capacitación	100%
Acompañamiento del consultor	100%
Percepción de mejora en seguridad	100%
Recomendación del servicio	100%

28.3 Comentarios abiertos destacados

- "Antes no sabíamos que conectar una USB podía ser tan peligroso. Ahora lo entendemos." – Analista de créditos.
- "Las políticas son claras, pero al principio cuesta acostumbrarse a cambiar la contraseña cada 90 días." – Cajero.

- "Me gustó que nos explicaran con ejemplos reales de lo que nos pasó." – Encargado de tesorería.

- "Ojalá se repita la capacitación cada año." – Encargada de Recursos Humanos.

XXIX. Conclusión de la encuesta

Los resultados reflejan un alto nivel de satisfacción con el servicio de consultoría informática. El personal valora la claridad de las políticas, la calidad de la capacitación y el acompañamiento recibido. La percepción de mejora en la seguridad es unánime (100%), lo que indica que el servicio no solo cumplió con los objetivos técnicos, sino que también generó un cambio cultural positivo en el banco. Se recomienda repetir la encuesta anualmente para medir la evolución de la percepción y detectar oportunidades de mejora.

XXX. Recomendaciones

Con base en los resultados del diagnóstico, la implementación de las 5 políticas de seguridad y el período de monitoreo, SecureInfo presenta las siguientes recomendaciones al Banco Cooperativo del Sur, S.A.:

30.1 Mantener las auditorías periódicas.

Se recomienda continuar con las auditorías trimestrales de logs de conexión USB, accesos a bases de datos y envíos de correo, tal como se realizó durante el monitoreo. Esto permite detectar a tiempo cualquier intento de incumplimiento y reforzar la cultura de prevención.

30.2 Repetir la capacitación anualmente.

La capacitación debe ser obligatoria para todo el personal, especialmente para nuevos ingresos. Se sugiere incluir casos prácticos actualizados y una evaluación final para medir el aprendizaje. La encuesta reflejó que el 100% del personal la consideró buena o excelente, y varios pidieron repetirla cada año.

30.3 Actualizar las políticas según la evolución tecnológica.

Las políticas deben revisarse al menos una vez al año o cuando ocurran cambios significativos en la infraestructura del banco (nuevos sistemas, migración a la nube, adopción de nuevas herramientas). La seguridad es dinámica y las políticas deben adaptarse.

30.4 Implementar autenticación de dos factores (2FA)

Aunque la Política 002 lo menciona para accesos remotos, se recomienda extenderlo a todos los accesos a sistemas críticos (banca en línea, bases de datos de clientes, tesorería). Esto agrega una capa adicional de protección contra el robo de credenciales.

30.5 Fomentar una cultura de seguridad

Más allá de las políticas, se recomienda promover una cultura de seguridad mediante charlas breves, correos internos con tips, y un canal de reporte de incidentes ágil y confidencial. La seguridad debe ser parte del día a día, no solo un documento.

30.6 Lecciones Aprendidas del Caso Práctico

La experiencia adquirida durante este proyecto demuestra que contar con un sistema de seguridad (firewall, antivirus o respaldos) no garantiza que una entidad esté completamente blindada; el caso del Banco Cooperativo del Sur, S.A. (Entidad Ficticia) evidenció que las fugas

de información más graves no provinieron de ataques externos sofisticados, sino de factores internos como el desconocimiento, la costumbre y la falta de políticas claras. Aunque el banco contaba con herramientas técnicas básicas, estas resultaron insuficientes porque el personal no sabía cómo usarlas correctamente ni qué conductas evitar, lo que confirma que la ignorancia puede convertirse en el mayor riesgo de seguridad. Por ello, la principal lección es que la protección de la información es un esfuerzo integral que combina tecnología, políticas y, sobre todo, conocimiento: sin capacitación, concienciación y una cultura de seguridad sólida, ningún sistema estará realmente protegido.

XXXI. Conclusión

el proyecto de SecureInfo nos permite que la ciberseguridad en el entorno de las empresas ha dejado de ser algo antiguo y se ha vuelto un componente técnico importante en todas las áreas gubernamentales y Privadas, a través del análisis realizado se demuestra que la viabilidad de la empresa radica en el enfoque proactivo y preventivo, el cual rompe los métodos tradicionales de seguridad a una optimización basada en políticas actuales que eviten la vulnerabilidad de la información confidencial que mantienen las empresas, el proyecto nos demuestra el blindaje que puede contener es integral, combinando las herramientas avanzadas con políticas de concientización orientado a la reducción del error humano, la contratación de los servicios de SecureInfo ofrece a las empresas genera la estabilidad, ofreciendo una solución altamente escalable competitiva y una alta relevancia comercial ante la demanda en el mercado digital y de Seguridad.